

Digital Security Research Group: Excel formula injection in Google Docs

Digital Security Research Group: Excel formula injection in Google Docs - Author not stated, dsecrg.blogspot.com.

- Published: date not stated
- Original: <<https://dsecrg.blogspot.com/2011/12/excel-formula-injection-in-google-docs.html>>
- Preserved from: <https://dsecrg.blogspot.com/2011/12/excel-formula-injection-in-google-docs.html> (stored) on 2026-08-06
- Capture timestamp: 20120530173011
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Surely all of you know about [Google reward program](#) for information security researchers who provide information about weak spots of Google resources. We had the chance to participate in this program, too. Here is a short story from [@_chipik](#) and [@asintsov](#).

One day we needed to conduct a small survey, and we decided to use Google Docs as platform for the survey. There is an object in Google Docs called Google Forms, and, as obvious from the name, it is used to create various surveys and tests forms.

[[image: image]](<http://2.bp.blogspot.com/-MrWrGWO9hKE/TvGzSWgFwyl/AAAAAAAAABg/mIC1thXPtnc/s1600/1.png>)

After a form is created, its URL is published on the Internet or sent to people who are to participate in the survey. This is how the form looks for a participant:

[[image: image]](http://1.bp.blogspot.com/-l0QXVfpDqXM/TvGz6hbb4zl/AAAAAAAAABs/hO_VWLg2Kgw/s1600/2.png)

And this is how the author sees the participant's answers:

[[image: image]]

(<http://2.bp.blogspot.com/-9sDiVPOEPfo/TvG0FaMxoel/AAAAAAAAAB4/aUbC2JbdzOI/s1600/3.png>)

I suppose that any web researcher upon seeing a form instinctively puts '","> and other interesting symbols here? We tried it, too. However, everything was encoded and filtered exactly as planned. Well... But all of user input is inserted into an Excel table, so why don't we try to inject some formula? Excel formulas start with an "=" . OK, let's give it a try.

[[image: image]]([http://3.bp.blogspot.com/-](http://3.bp.blogspot.com/-CII6iU1vq0A/TvG0Pi7Vdul/AAAAAAAAACE/CazltRKQ3Fg/s1600/4.png)

CI6iU1vq0A/TvG0Pi7Vdul/AAAAAAAAACE/CazltRKQ3Fg/s1600/4.png) Fail. Cunning Google puts a space symbol before the "=" so that the formula is taken for a simple text cell. So how do we get rid of the space? Easy as pie: use backspace :) %08 is the Hex code of the backspace key.

[[image: image]](<http://2.bp.blogspot.com/-NI5xgDHxMbc/TvG0WPMuVQI/AAAAAAAAACQ/TGtjB4-3cds/s1600/5.png>)

Thus, we wrote in the entry field: %08=1+2+C3

Voila!

[[image: image]]

(<http://4.bp.blogspot.com/-8S6IeweFWv4/TvG0dx7tasI/AAAAAAAAACc/P236NHaeG6w/s1600/6.png>)The formula got inserted into the table just fine. All we had to do now was devise an interesting and practical vector for this particular injection. Google Functions helped us here.

[[image: image]]([http://1.bp.blogspot.com/-](http://1.bp.blogspot.com/-I_K5LyZaCZc/TvG0op_rEHl/AAAAAAAAACo/nv7rPNrAV5w/s1600/7.png)

I_K5LyZaCZc/TvG0op_rEHl/AAAAAAAAACo/nv7rPNrAV5w/s1600/7.png)With the help of Google Functions it was possible to execute a request to any domain so that the request results got inserted into a specified cell.

That gave us the following attack vector:

1. Put sensitive user data into A1 cell (or probably they are already there)
2. Put a formula which makes GET request to http://own_site.com/secret_data_in_base64 into Z666 cell.
3. Read web server logs, get data from cells.
4. Profit!

Soon after describing the bug and the possible attack vector we got the following letter:

[[image: image]]([http://2.bp.blogspot.com/-](http://2.bp.blogspot.com/-jVXEhZX74Uw/TvG045MPgrI/AAAAAAAAAC0/IWhvttXYIcM/s1600/8.png)

jVXEhZX74Uw/TvG045MPgrI/AAAAAAAAAC0/IWhvttXYIcM/s1600/8.png) And a bit later we saw our names in [Google Hall of Fame](#)

[[image: image]](<http://4.bp.blogspot.com/-IQdJqavXli4/TvG1N8e9q5I/AAAAAAAAADM/-dX1kxzqDx8/s1600/9.png>)Finally, a little Google Hack ;)

[[image: image]]([http://4.bp.blogspot.com/-](http://4.bp.blogspot.com/-ydl_YeYaxX8/TvG1FrESW1I/AAAAAAAAADA/eHog0_7qsJ0/s1600/10.png)

ydl_YeYaxX8/TvG1FrESW1I/AAAAAAAAADA/eHog0_7qsJ0/s1600/10.png)